

Nmap Vulners Scan Evidence (Outdated Server Components)

CRITICAL Target: OWASP/bWAPP (Buggy Web Application) — Lab IT Audit

1. Informasi Pengujian

Tanggal Pengujian	17 Juni 2026
Tool	Nmap 7.94SVN + skrip NSE vulners dan http-server-header
Metode	Deteksi versi layanan (-sV), lalu pencocokan CPE ke basis data kerentanan vulners.com
Target	http://localhost:8080/ (port 8080/tcp)
Perintah	nmap -sV --script vulners,http-server-header -p 8080 localhost

2. Komponen Terdeteksi

Layanan	Versi	CPE	Sumber
HTTP Server	Apache httpd 2.4.7 (Ubuntu)	cpe:/a:apache:http_server:2.4.7	Deteksi versi nmap
Interpreter	PHP 5.5.9-1ubuntu4.14	cpe:/a:php:php:5.5.9	Header X-Powered-By

Apache 2.4.7 (rilis 2014) dan PHP 5.5.9 (PHP 5.5 mencapai End-of-Life pada Juli 2016) keduanya sudah jauh melewati masa dukungan keamanan.

3. Ringkasan Kerentanan (Apache httpd 2.4.7)

Skrip vulners mencocokkan versi Apache dengan **106 CVE unik**. Distribusi tingkat keparahan (berdasarkan skor CVSS yang dilaporkan vulners):

Tingkat	Rentang CVSS	Jumlah CVE
Critical	9.0 - 10.0	24
High	7.0 - 8.9	42
Medium	4.0 - 6.9	40

Selain CVE, scan menandai **52 entri ber-label *EXPLOIT*** (exploit publik tersedia, mis. ExploitDB, PacketStorm, Metasploit/Seebug), termasuk satu entri berskor 10.0.

Contoh CVE Critical (CVSS 9.8) pada Apache 2.4.7

CVE	CVSS	Keterangan singkat
CVE-2024-38476	9.8	SSRF/eksekusi via backend tak tepercaya (mod_proxy)
CVE-2023-25690	9.8	HTTP request smuggling via mod_proxy + RewriteRule
CVE-2022-31813	9.8	Penghapusan header X-Forwarded-* (bypass otorisasi)

CVE-2022-22720	9 . 8	HTTP request smuggling (penanganan koneksi tidak valid)
CVE-2021-44790	9 . 8	Buffer overflow pada mod_lua (multipart parsing)
CVE-2021-39275	9 . 8	Out-of-bounds write pada ap_escape_quotes
CVE-2017-7679	9 . 8	Buffer over-read pada mod_mime
CVE-2017-3169	9 . 8	NULL pointer dereference pada mod_ssl

Daftar lengkap 106 CVE tersimpan sebagai arsip mentah di `doc/nmap_output/nmap_vulners.txt`.

Catatan metodologi (penting untuk interpretasi): Skrip `vulners` mencocokkan kerentanan **berdasarkan banner versi (CPE) saja**, bukan dengan menguji eksploitasi secara langsung. Distribusi paket Ubuntu sering melakukan *backport* tambalan keamanan tanpa menaikkan nomor versi, sehingga sebagian CVE dalam daftar mungkin sudah ditambah pada build spesifik ini. Daftar ini valid sebagai indikator **permukaan risiko komponen usang**, dan untuk konfirmasi per-CVE diperlukan verifikasi versi paket atau pengujian eksploitasi terkontrol. Sebagian entri (mis. ber-ID tahun mendatang) juga dapat berupa noise pencocokan.

4. PHP 5.5.9

PHP 5.5.9 tidak dipindai `vulners` sebagai layanan terpisah (terdeteksi via header, bukan port khusus), namun statusnya yang **End-of-Life sejak 2016** menjadikannya temuan A06 tersendiri. Cabang PHP 5.5 tidak lagi menerima pembaruan keamanan dan memiliki sejumlah besar CVE yang diketahui. Disarankan migrasi ke versi PHP yang masih didukung (8.x).

5. Penilaian Risiko

Aspek	Keterangan
Severity	CRITICAL

Root Cause	Server web (Apache 2.4.7) dan interpreter (PHP 5.5.9) berjalan pada versi end-of-life tanpa pembaruan keamanan
Impact	Permukaan serangan luas: request smuggling, SSRF, buffer overflow, dan bypass otorisasi; banyak memiliki exploit publik
Keterkaitan Temuan Lain	Melengkapi temuan Nikto yang menandai versi usang, dengan pemetaan ke ID CVE konkret

6. Rekomendasi Remediasi

1. **Perbarui Apache httpd** ke rilis stabil terkini (cabang 2.4.x yang didukung) atau gunakan paket OS yang aktif menerima tambalan keamanan.
2. **Migrasi PHP** dari 5.5.9 ke versi yang masih didukung (PHP 8.x).
3. Tegakkan **manajemen patch** dan pemindaian komponen berkala (SCA) sebagai bagian dari siklus pemeliharaan.
4. Sembunyikan/minimalkan **banner versi** (ServerTokens Prod, nonaktifkan X-Powered-By) untuk mengurangi kemudahan enumerasi oleh penyerang (mitigasi berlapis, bukan pengganti patch).